

1. Objet et portée

Cette politique définit le processus d'investigation de BantuDelice pour tout incident de sécurité signalant un possible accès non autorisé aux données de la plateforme hébergée sur le serveur VPS de production (*vps-0e8f1563.vps.ovh.net*). Elle couvre l'ensemble du cycle : détection, triage, investigation, correction et notification des parties prenantes, y compris Meta.

Sont concernées : les données utilisateurs (comptes, commandes, adresses), les données de livraison, les informations financières, et tout accès non autorisé aux systèmes d'authentification ou aux fichiers de configuration sensibles.

2. Sources de détection des incidents

Les alertes de sécurité sont générées par les systèmes suivants :

- **fail2ban** : bannissements automatiques IP SSH (seuil 5 tentatives / 15 min) + jail permanent
- **auditd** : alertes sur modifications de comptes, élévations de privilèges, accès fichiers sensibles
- **security-audit.sh** : rapport hebdomadaire (chaque lundi 08:00 UTC) — statut LOW / MODERATE / REVIEW RECOMMENDED
- **Sentry** : erreurs applicatives critiques (niveau ERROR/CRITICAL dans les logs Laravel)
- **Nginx access.log** : sondes de chemins sensibles (/ .env, /.git, /wp-admin), réponses 4xx/5xx anormales

3. Triage — Détermination de la validité de l'événement

★ CONDITION REQUISE — META APP REVIEW : ÉTAPES DE TRIAGE (SURLIGNÉES)

Étapes permettant de déterminer la validité ou l'invalidité des événements de sécurité (vrais positifs ou faux positifs) :

- **Étape T1 — Collecte des preuves** : extraire les entrées de log concernées (ausearch, grep sur auth.log/nginx/laravel), horodater l'événement, identifier l'IP et l'user-agent source.
- **Étape T2 — Confrontation avec les baselines** : comparer l'IP source avec les accès administrateurs connus (/var/log/auth.log historique), vérifier si l'heure correspond à une fenêtre de maintenance planifiée.
- **Étape T3 — Critères de faux positif** : IP appartenant à un administrateur autorisé (liste blanche), action effectuée pendant une fenêtre de déploiement documentée, compteur d'erreurs dans la variance habituelle ($\pm 20\%$ de la baseline hebdomadaire).
- **Étape T4 — Critères de vrai positif** : IP inconnue accédant à des ressources protégées avec code 200, nouveau compte admin créé sans ticket d'autorisation, accès à .env ou /var/log/audit/ hors processus autorisés, volume de requêtes >100/min depuis une IP unique.
- **Étape T5 — Décision de triage** : si vrai positif confirmé → activer le processus d'escalade (section 4) ; si faux positif → documenter dans le rapport d'audit hebdomadaire et ajuster les règles de détection si nécessaire.

Matrice de sévérité

Sévérité	Critères	Délai de réponse
P1 — Critique	Exfiltration de données confirmée, accès root non autorisé, compte admin compromis, base de données accessible sans authentification	Immédiat — <1h
P2 — Élevé	Tentative d'élévation de privilèges, injection SQL détectée dans les logs, modification non autorisée de configuration Nginx/Laravel	<4h
P3 — Modéré	Sondes répétées de chemins sensibles depuis une IP unique, >500 tentatives SSH en 24h depuis une IP non bannie	<24h
P4 — Faible	Hausse inhabituelle des erreurs 404, fail2ban MODERATE sans exfiltration détectée	<7 jours (prochain rapport)

4. Escalade — Investigation, correction et notification

★ CONDITION REQUISE — META APP REVIEW : ÉTAPES D'ESCALADE (SURLIGNÉES)

Étapes d'escalade : suivi, investigation, correction des incidents et notification des parties prenantes internes concernées :

🔒 Confinement immédiat (P1/P2)

- Bannissement manuel de l'IP suspecte : fail2ban-client set sshd-permanent banip <IP>
- Révocation des sessions actives suspectes : pkill -u <user> / invalidation tokens Laravel
- Blocage Nginx temporaire si nécessaire : ajout IP danssnippets/deny-sensitive.conf
- Isolation du compte compromis : usermod -L <user> (verrouillage immédiat)

🔍 Investigation forensique

- Extraire timeline complète : ausearch -ts <date> -te <date> | aureport --summary
- Identifier toutes les actions effectuées : ausearch -ua <uid> -i
- Vérifier intégrité des fichiers : debsums -c + comparaison checksum .env
- Analyser patterns d'accès : grep <IP> /var/log/nginx/access.log | awk '{print \$7}' | sort | uniq -c
- Déterminer périmètre des données potentiellement exposées (tables, colonnes, volume)

3 Correction et remédiation

- Rotation des secrets compromis : clés API, tokens, APP_KEY Laravel, credentials base de données
- Révocation et régénération des certificats SSL si nécessaire
- Correction de la vulnérabilité exploitée (patch, configuration, règle WAF)
- Renforcement des règles fail2ban si seuil dépassé
- Vérification complète : nginx -t && systemctl reload nginx + smoke tests applicatifs

4 Notification des parties prenantes internes

En cas de vrai positif (P1 ou P2), les parties prenantes internes sont notifiées immédiatement :

- **Responsable technique** : notification dans l'heure via canal d'urgence (email + SMS)
- **Direction BantuDelice** : rapport d'incident dans les 4h avec périmètre estimé et actions prises
- **Support client** : si des données utilisateurs sont concernées, préparation d'une communication client

5. Signalement à Meta — Obligation de notification immédiate

⚠ OBLIGATION DE SIGNALEMENT — META (SURLIGNÉE)

En cas d'incident de sécurité confirmé, BantuDelice s'engage à signaler immédiatement l'incident à Meta conformément aux politiques de Meta. Ce signalement est effectué dès la confirmation du vrai positif (étape T5), sans attendre la fin de l'investigation.

Le signalement à Meta inclut : la nature de l'incident, les données potentiellement affectées, les actions de confinement déjà prises, et le calendrier d'investigation prévu.

6. Revue post-incident

Dans les 7 jours suivant la résolution d'un incident P1/P2 :

- Rédaction du rapport post-incident (timeline, cause racine, impact réel, correctifs appliqués)
- Mise à jour des règles de détection auditd et fail2ban pour prévenir la récurrence
- Revue des permissions d'accès et révocation des accès non nécessaires (principe de moindre privilège)
- Archivage du dossier d'incident dans /opt/bantudelice/storage/logs/incidents/

Responsable politique

BantuDelice — Équipe technique

Date d'entrée en vigueur

2026-06-03

Prochaine révision

2026-12-03 (semestrielle)

Référence Meta

journal d'audit-22.g.i